

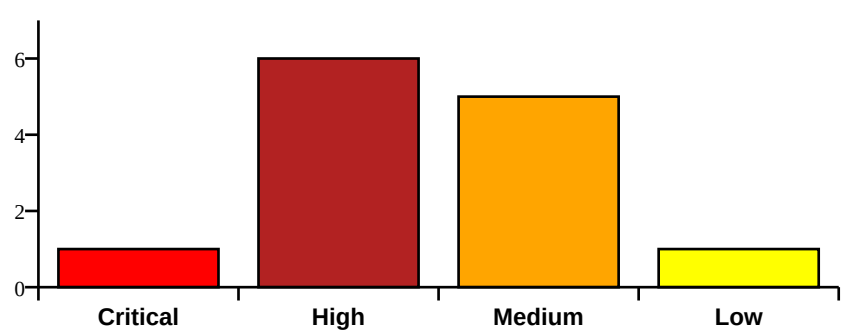
Vulnerability Scan Report

Target URL: http://testphp.vulnweb.com/login.php
Generated (UTC): 2025-12-23 18:15:39Z

Summary

Metric	Count
Total Vulnerabilities	13
Critical Severity	1
High Severity	6
Medium Severity	5
Low Severity	1

Severity Distribution



Detected Vulnerabilities

Type	Location	Evidence / Payload	Severity
XSS	http://testphp.vulnweb.com/login.php	'-alert(1)//	Medium
XSS	http://testphp.vulnweb.com/login.php	alert(1);	Medium
SQL Injection	http://testphp.vulnweb.com/login.php	OR '1'='1 --	High
SQL Injection	http://testphp.vulnweb.com/login.php	OR '1'='1 --	High
NoSQL Injection	http://testphp.vulnweb.com/login.php	{"\$ne": null}	High
Command Injection	http://testphp.vulnweb.com/login.php	;& ls	Critical
Cryptographic Failure	http://testphp.vulnweb.com/login.php	Issue: Application does not enforce HTTPS	High
Cryptographic Failure	http://testphp.vulnweb.com/login.php	Issue: Strict-Transport-Security header not set	Medium
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: Multiple rapid requests allowed without restriction	High

Insecure Design	http://testphp.vulnweb.com/login.php	Issue: Sensitive endpoint accessible without auth: /admin	High
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: No CAPTCHA or bot protection detected	Low
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: PUT method is enabled	Medium
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: DELETE method is enabled	Medium

Activity Log

```
[18:14:43] [+] Loaded 6606 payloads for XSS
[18:14:43] [+] Loaded 4 payloads for SQL Injection
[18:14:43] [+] Loaded 3 payloads for NoSQL Injection
[18:14:43] [+] Loaded 4 payloads for Command Injection
[18:14:44] [+] Found: http://testphp.vulnweb.com/login.php
[18:14:44]
=====
[18:14:44] Starting Vulnerability Scan for http://testphp.vulnweb.com/login.php
[18:14:44]
=====
[18:14:44]
===== Testing for XSS =====
[18:14:45]
[+] Testing form in http://testphp.vulnweb.com/login.php
[18:14:54] [***] Possible XSS in form at: http://testphp.vulnweb.com/login.php
[18:14:54] payload: &#x27;-alert(1)//
[18:14:54] Severity: Medium
[18:14:54] form: <form action=&quot;userinfo.php&quot; method=&quot;post&quot; name=&quot;loginform&quot; >
<table cellpadding=&quot;4&quot; cellspacing=&quot;1&quot; >
<tr><td>Username : </td><td><input name=&quot;uname&quot; size=&quot;20&quot; style=&quot;width:120px;&quot;
type=&quot;text&quot; /></td></tr>
<tr><td>Password : </td><td><input name=&quot;pass&quot; size=&quot;20&quot; style=&quot;width:120px;&quot;
type=&quot;password&quot; /></td></tr>
<tr><td align=&quot;right&quot; colspan=&quot;2&quot; ><input style=&quot;width:75px;&quot;
type=&quot;submit&quot; value=&quot;login&quot; /></td></tr>
</table>
</form>

[18:14:54]
[+] Testing form in http://testphp.vulnweb.com/login.php
[18:14:54] [***] Possible XSS in form at: http://testphp.vulnweb.com/login.php
[18:14:54] payload: <script>alert(1);</script>
[18:14:54] Severity: Medium
[18:14:54] form: <form action=&quot;search.php?test=query&quot; method=&quot;post&quot; >
<label>search art</label>
<input name=&quot;searchFor&quot; size=&quot;10&quot; type=&quot;text&quot; />
<input name=&quot;goButton&quot; type=&quot;submit&quot; value=&quot;go&quot; />
</form>

[18:14:54]
===== Testing for SQL Injection =====
[18:14:55]
[+] Testing form in http://testphp.vulnweb.com/login.php
[18:14:55] [***] Possible SQL Injection in form at: http://testphp.vulnweb.com/login.php
[18:14:55] payload: OR &#x27;1&#x27;=&#x27;1 --
[18:14:55] Severity: High
[18:14:55] form: <form action=&quot;userinfo.php&quot; method=&quot;post&quot; name=&quot;loginform&quot; >
<table cellpadding=&quot;4&quot; cellspacing=&quot;1&quot; >
<tr><td>Username : </td><td><input name=&quot;uname&quot; size=&quot;20&quot; style=&quot;width:120px;&quot;
type=&quot;text&quot; /></td></tr>
<tr><td>Password : </td><td><input name=&quot;pass&quot; size=&quot;20&quot; style=&quot;width:120px;&quot;
type=&quot;password&quot; /></td></tr>
<tr><td align=&quot;right&quot; colspan=&quot;2&quot; ><input style=&quot;width:75px;&quot;
type=&quot;submit&quot; value=&quot;login&quot; /></td></tr>
</table>
</form>

[18:14:55]
[+] Testing form in http://testphp.vulnweb.com/login.php
[18:14:55] [***] Possible SQL Injection in form at: http://testphp.vulnweb.com/login.php
[18:14:55] payload: OR &#x27;1&#x27;=&#x27;1 --
[18:14:55] Severity: High
[18:14:55] form: <form action=&quot;search.php?test=query&quot; method=&quot;post&quot; >
<label>search art</label>
```

```
<input name=&quot;searchFor&quot; size=&quot;10&quot; type=&quot;text&quot; />
<input name=&quot;goButton&quot; type=&quot;submit&quot; value=&quot;go&quot; />
</form>
```

```
[18:14:55]
===== Testing for NoSQL Injection =====
[18:14:56]
[+] Testing form in http://testphp.vulnweb.com/login.php
[18:14:58]
[+] Testing form in http://testphp.vulnweb.com/login.php
[18:14:58] [***] Possible NoSQL Injection in form at: http://testphp.vulnweb.com/login.php
[18:14:58] payload: {&quot;$ne&quot;;: null}
[18:14:58] Severity: High
[18:14:58] form: <form action=&quot;search.php?test=query&quot; method=&quot;post&quot;>
<label>search art</label>
<input name=&quot;searchFor&quot; size=&quot;10&quot; type=&quot;text&quot; />
<input name=&quot;goButton&quot; type=&quot;submit&quot; value=&quot;go&quot; />
</form>
```

```
[18:14:58]
===== Testing for Command Injection =====
[18:14:58]
[+] Testing form in http://testphp.vulnweb.com/login.php
[18:15:01]
[+] Testing form in http://testphp.vulnweb.com/login.php
[18:15:02] [***] Possible Command Injection in form at: http://testphp.vulnweb.com/login.php
[18:15:02] payload: ;&amp; ls
[18:15:02] Severity: Critical
[18:15:02] form: <form action=&quot;search.php?test=query&quot; method=&quot;post&quot;>
<label>search art</label>
<input name=&quot;searchFor&quot; size=&quot;10&quot; type=&quot;text&quot; />
<input name=&quot;goButton&quot; type=&quot;submit&quot; value=&quot;go&quot; />
</form>
```

```
[18:15:02]
===== Testing for Cryptographic Failures =====
[18:15:02]
===== SCANNING http://testphp.vulnweb.com/login.php =====
```

```
[18:15:02] [INFO] Checking scheme → http
[18:15:02] [INFO] Initiating TLS handshake
[18:15:07] [SKIP] TLS check skipped → timed out
[18:15:07] [INFO] Checking cipher suite
[18:15:12] [SKIP] Cipher check skipped → timed out
[18:15:12] [INFO] Retrieving TLS certificate
[18:15:17] [SKIP] Certificate check skipped → timed out
[18:15:17] [HTTP] Checking HSTS header
[18:15:17] [HTTP] Response status → 200
[18:15:17] [HTTP] Response headers → {&#x27;Server&#x27;; &#x27;nginx/1.19.0&#x27;;, &#x27;Date&#x27;;:
&#x27;Tue, 23 Dec 2025 18:16:38 GMT&#x27;;, &#x27;Content-Type&#x27;;: &#x27;text/html; charset=UTF-8&#x27;;,
&#x27;Transfer-Encoding&#x27;;: &#x27;chunked&#x27;;, &#x27;Connection&#x27;;: &#x27;keep-alive&#x27;;,
&#x27;X-Powered-By&#x27;;: &#x27;PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1&#x27;;, &#x27;Content-
Encoding&#x27;;: &#x27;gzip&#x27;;}
[18:15:17] [SCAN] Checking for weak hashes and sensitive data
```

```
[18:15:18]
===== REPORT =====
[18:15:18] - [High] HTTPS not enforced
[18:15:18] - [Medium] HSTS header missing
[18:15:18]
```

```
===== SCORE =====
[18:15:18] Crypto Risk Score → 50/100
[18:15:18] Risk Level → MEDIUM
[18:15:18]
```

```
===== Insecure Design Scan =====
```

```
[18:15:18]
[+] Checking rate limiting...
[18:15:18] [LOG] GET /login.php → 200 (len=5523, 0.55s)
[18:15:19] [LOG] GET /login.php → 200 (len=5523, 0.54s)
[18:15:20] [LOG] GET /login.php → 200 (len=5523, 0.56s)
[18:15:21] [LOG] GET /login.php → 200 (len=5523, 0.56s)
[18:15:22] [LOG] GET /login.php → 200 (len=5523, 0.56s)
[18:15:22] [LOG] GET /login.php → 200 (len=5523, 0.54s)
[18:15:23] [LOG] GET /login.php → 200 (len=5523, 0.54s)
[18:15:24] [LOG] GET /login.php → 200 (len=5523, 0.56s)
[18:15:24]
[+] Checking authorization design...
[18:15:25] [LOG] GET /admin → 200 (len=262, 0.83s)
[18:15:25] [LOG] GET /admin/login → 404 (len=153, 0.56s)
[18:15:26] [LOG] GET /administrator → 404 (len=153, 0.53s)
[18:15:27] [LOG] GET /manage → 404 (len=153, 0.55s)
[18:15:27] [LOG] GET /user → 404 (len=153, 0.55s)
```

[18:15:28] [LOG] GET /account → 404 (len=153, 0.54s)
[18:15:28] [LOG] GET /profile → 404 (len=153, 0.53s)
[18:15:29] [LOG] GET /login → 404 (len=153, 0.57s)
[18:15:29] [LOG] GET /register → 404 (len=153, 0.55s)
[18:15:30] [LOG] GET /auth → 404 (len=153, 0.55s)
[18:15:30] [LOG] GET /api → 404 (len=153, 0.54s)
[18:15:31] [LOG] GET /api/admin → 404 (len=153, 0.57s)
[18:15:32] [LOG] GET /api/private → 404 (len=153, 0.54s)
[18:15:32] [LOG] GET /checkout → 404 (len=153, 0.55s)
[18:15:33] [LOG] GET /payment → 404 (len=153, 0.58s)
[18:15:33] [LOG] GET /orders → 404 (len=153, 0.56s)
[18:15:34] [LOG] GET /upload → 404 (len=153, 0.58s)
[18:15:35] [LOG] GET /debug → 404 (len=153, 0.55s)
[18:15:35] [LOG] GET /test → 404 (len=153, 0.54s)
[18:15:36] [LOG] GET /dev → 404 (len=153, 0.55s)
[18:15:36]
[+] Checking business logic trust...
[18:15:36] [LOG] POST /login.php → 200 (len=5523, 0.55s)
[18:15:36] ✓ Business logic validation detected
[18:15:36]
[+] Checking abuse protection (CAPTCHA)...
[18:15:37] [LOG] GET /login.php → 200 (len=5523, 0.56s)
[18:15:37]
[+] Checking HTTP method exposure...
[18:15:37] [LOG] PUT /login.php → 200 (len=5523, 0.56s)
[18:15:38] [LOG] DELETE /login.php → 200 (len=5523, 0.57s)
[18:15:39] [LOG] TRACE /login.php → 405 (len=157, 0.57s)